# Passive Reconnaissance

What it is, why it matters, and how to do it

Beginner guide for junior penetration testers | Kali Linux | Lab target: example.com

**In one sentence:** passive reconnaissance means collecting information about a target from public sources, without sending traffic to the target's own systems or interacting with them in a way that could be detected.

## 1. What is passive reconnaissance?

Reconnaissance (or "recon") is the first phase of a security assessment. Before testing anything, a penetration tester needs to understand what the target looks like from the outside: which domains it owns, who hosts its DNS, how its email is routed, and what technology it appears to use.

In **passive** recon, the information comes from third parties and public records such as WHOIS databases, public DNS, search engines, certificate transparency logs and web archives. The tester never probes the target's servers directly.

### Passive vs. active reconnaissance

| | Passive recon | Active recon |
|---|---|---|
| Contact with target | None or indistinguishable from normal public traffic | Direct: packets are sent to target systems |
| Detection risk | Very low | Can appear in logs, IDS and firewalls |
| Examples | WHOIS, DNS lookups, search engines, certificate logs | Port scanning, banner grabbing, vulnerability scanning |
| Authorization | Still needs a defined scope for professional work | Written permission is mandatory |

Note: DNS lookups sent through a public resolver are generally treated as passive, because the target is not scanned. Queries sent straight to the target's own name servers can show up in their logs, so the boundary is not absolute.

## 2. Why do it?

- **Map the attack surface:** find domains, name servers and mail servers that belong to the organization.
- **Define scope accurately:** confirm which assets are in scope before any active testing begins.
- **Stay quiet:** collect useful data with almost no risk of alerting the target or disrupting services.

- **Plan the next steps:** good recon decides which tools and techniques are worth using later.
- **Understand defenders' view:** the same public data is what real attackers see, so defenders use it to reduce exposure.

## 3. What information can you collect?

| Source | What it reveals |
|---|---|
| WHOIS | Registrar, creation/update/expiry dates, name servers, domain status, sometimes registrant contacts (often redacted) |
| DNS records | IP addresses (A/AAAA), mail servers (MX), name servers (NS), text records (TXT), zone authority (SOA) |
| Search engines | Indexed pages, exposed documents, public mentions of the organization |
| Certificate transparency | Certificates issued for the domain, which often expose subdomain names |
| Web archives | Older versions of sites, retired pages and past technology |
| Public code and social sites | Staff roles, technology stack, accidentally published information |

This lab focuses on the first two rows (WHOIS and DNS). The others are natural next steps.

## 4. How to do it: step by step

**Before you start:** confirm you have permission or a defined scope for the target. For practice, use `example.com`, a domain reserved for documentation, or a domain you own.

### Step 1: Prepare your workspace

Create a folder structure so every result is saved as evidence.

```
mkdir -p ~/Passive-Recon/{Report,Evidence,Screenshots}
cd ~/Passive-Recon
```

### Step 2: Install and verify the tools

`whois` queries domain registration data. `dnsutils` provides `dig` and `nslookup` for DNS queries.

```
sudo apt update
sudo apt install dnsutils whois -y
dig -v
whois --version
```

### Step 3: Gather WHOIS information

```
whois example.com > Evidence/whois.txt 2>&1
cat Evidence/whois.txt
```

Look for the registrar, creation, updated and expiration dates, name servers, domain status, and registrant details. Many registrants are hidden by privacy services, which is normal.

## Step 4: Enumerate DNS records

Each record type answers a different question about the infrastructure.

| Record | Command | What it tells you |
|---|---|---|
| A | dig example.com A | IPv4 address the name points to |
| AAAA | dig example.com AAAA | IPv6 address, if configured |
| MX | dig example.com MX | Mail servers; lower priority number is preferred |
| NS | dig example.com NS | Authoritative name servers |
| TXT | dig example.com TXT | SPF, domain verification and other text data |
| SOA | dig example.com SOA | Primary server, serial number, refresh timers |

Save each result, for example:

```
dig example.com A > Evidence/dns-a.txt
dig example.com MX > Evidence/dns-mx.txt
```

To see only the answer section, add `+noall +answer`.

## Step 5: Cross-check with other resolvers and tools

DNS answers can differ by resolver and time. Comparing results helps you spot caching or inconsistencies.

```
dig @1.1.1.1 example.com A
nslookup example.com
```

A query of type ANY (`dig example.com ANY`) is worth trying once, but many servers return limited or no data for it, so do not treat it as a complete record list.

## Step 6: Verify and organize evidence

```
ls -lh Evidence/
for file in Evidence/*.txt; do
  echo "===== $file ====="
  cat "$file"
done
```

## Step 7: Take screenshots

- Tool installation and version check
- WHOIS output
- A and AAAA queries
- MX and NS queries
- TXT and SOA queries
- The Evidence folder listing

## 5. How to read the results

| Observation | What it may suggest |
|---|---|
| Name servers belong to a large provider | DNS is managed by a third party, which is relevant when defining scope |
| MX records point to a hosted email service | Email is outsourced; check which provider and what policies are published |
| TXT contains an SPF record | The domain publishes which servers may send mail for it |
| No AAAA record | No IPv6 service is advertised for that name |
| WHOIS shows redacted contacts | Privacy protection is enabled; contact data is not available |

**Important:** DNS data does not prove a server is online, reachable, or vulnerable. Recon produces leads, not findings of weakness.

## 6. Documenting your work

Good recon is only useful if it is recorded. For each step keep the exact command, the saved raw output, a short note on what it shows, and a screenshot. A simple report structure is:

- Executive summary and target information
- Environment preparation
- WHOIS findings
- DNS findings by record type
- Security relevance and limitations
- Conclusion and next steps

Before publishing evidence to GitHub, check the WHOIS file for any personal data.

## 7. Legal and ethical rules

- Only test targets you own or have written authorization to assess.
- Stay inside the agreed scope, even when passive data points to other organizations.
- Do not use recon results to exploit, scan or disrupt systems without explicit permission.
- Handle collected data, especially personal details, responsibly and store it securely.

## 8. Next steps

- Subdomain enumeration using certificate transparency and public sources, within authorized scope
- Reviewing SPF, DKIM and DMARC email security records
- Identifying technologies and hosting providers from public information

- Moving to active recon only after scope and permission are confirmed